TECH DAYS 2015

BREAKING NEW GROUND

Microsoft

Azure Governance

Foundational technology building blocks for enterprise control

Martin Vliem CISSP, CISA
Principal Cloud Technology Specialist
Microsoft
mvliem@microsoft.com

Agenda

- Introduction to Cloud governance challenges
- Azure governance controls all-up
- Enterprise controls
- Subscription & resource controls
- Access & audit controls
- Scenario

Microsoft

Cloud Challenges & fundamentals

Process & organizational maturity

Cloud Consumers/Customers new responsibilities; tenant ownership, service relationship management, service catalog

Enable innovation with Lifecycle Management

Financial processes, billing, chargeback and or showback

IT becoming a Service Provider

Different levels of automation (on-prem / cloud)

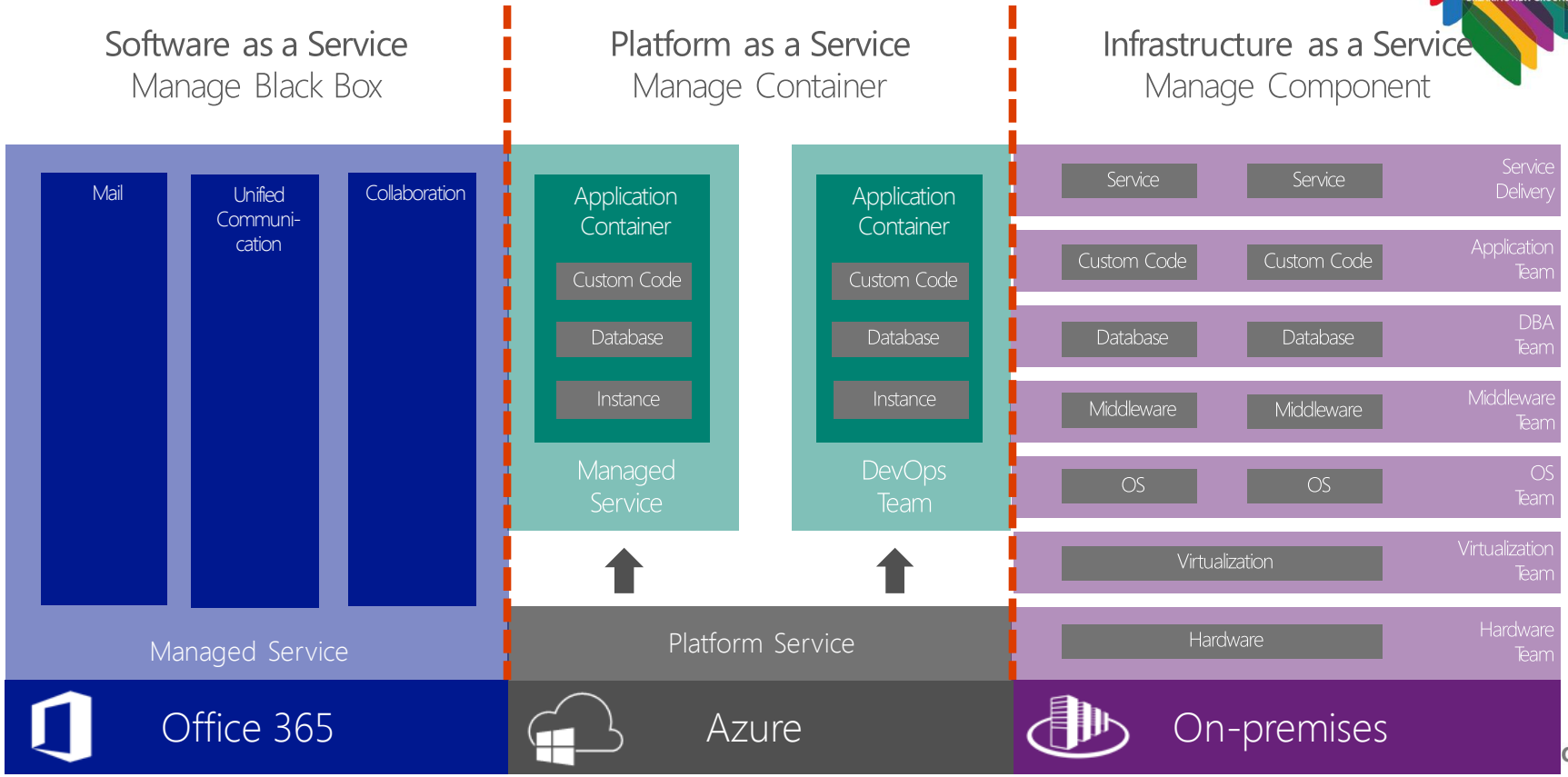
Security, connectivity (hybrid)

Access management and control

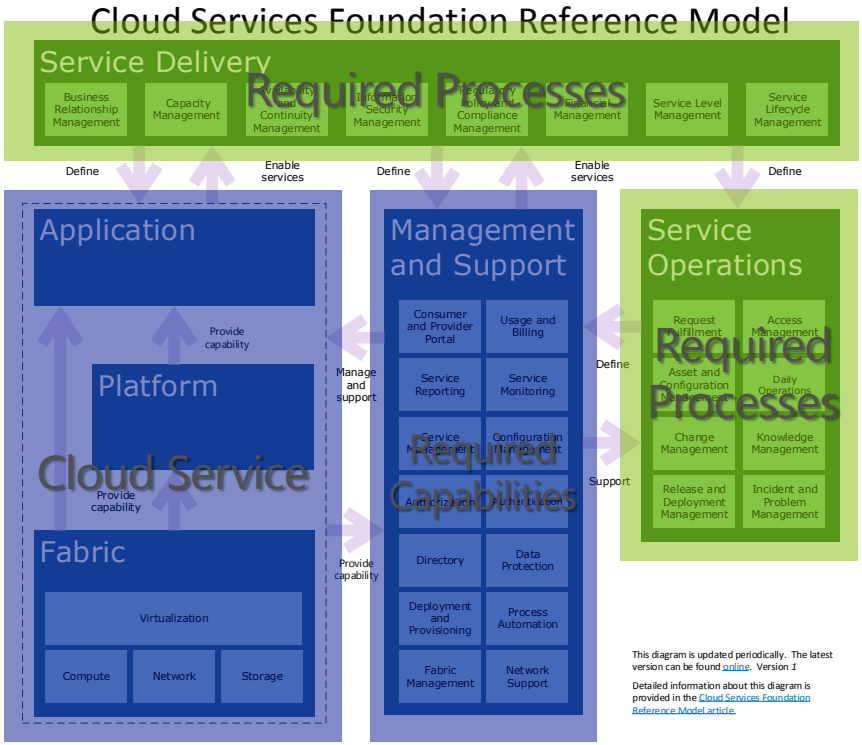
….

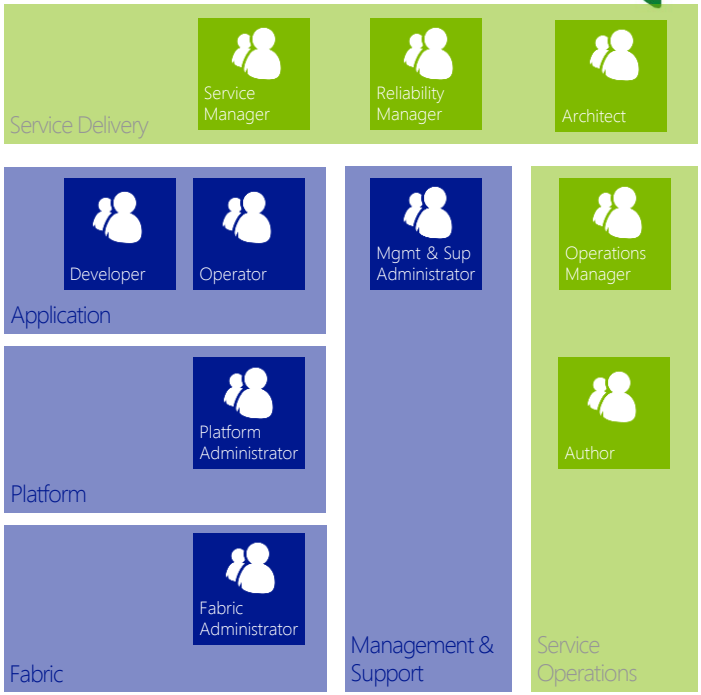
Microsoft

Changing governance structures



Changing processes and roles





http://aka.ms/Xzpey8

Microsoft

Need for controls!

1. Enterprise governance, risk, compliance
2. Resource level controls (organizing)
3. Access control, auditing & monitoring
4. Connectivity controls (hybrid networking)

Azure governance controls overview

Microsoft Azure non-functional controls

Physical Features

State-of-the-art security and access control. 200+ services delivered 24X7

Leading innovator in power efficiency

Thousands+ people in engineering and operations and major investments in cloud

Geo-Distribution

Multiple data centers in different geographies in 19 regions

Local, zone and geo-replication

Redundant platform services and failover

Platform Availability and Security

99.9% / 99.99% uptime, financially-backed SLAs

Highly available platform services

Service isolation over virtualized compute and network

Clear boundaries and multiple lines of defense

Compliance and DR

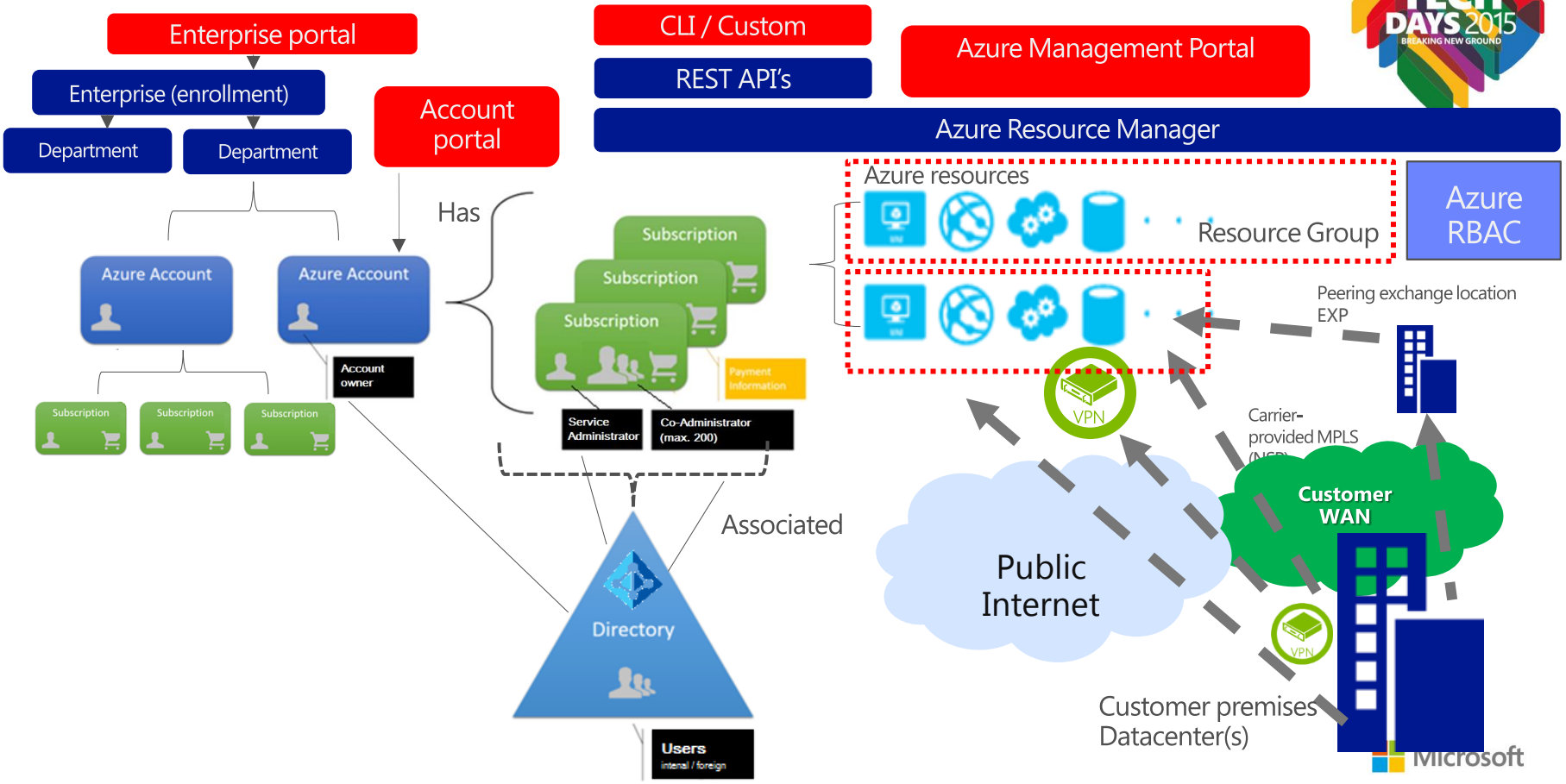
Broad compliance certifications

- ISO 27001:5000
- SSAE16 (SAS70-TII)
- HIPAA
- PCI-DSS
- EUDPD – Safe Harbor
- **Art 29 Working Party**
- EU Model Clauses
- ISO/IEC 27018
- Data Processing Agreement

Preparedness, testing, refinement

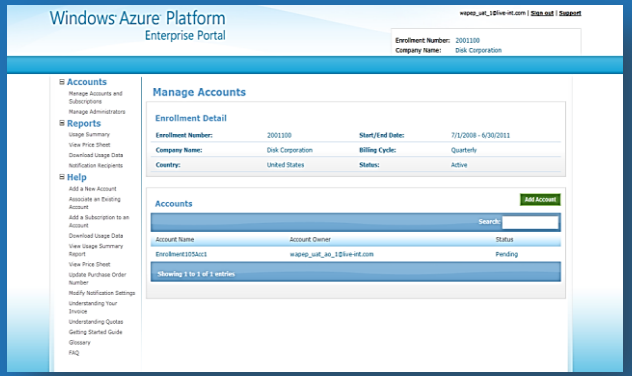
Microsoft

Understanding Azure governance structure



Enterprise level controls

Azure Portals

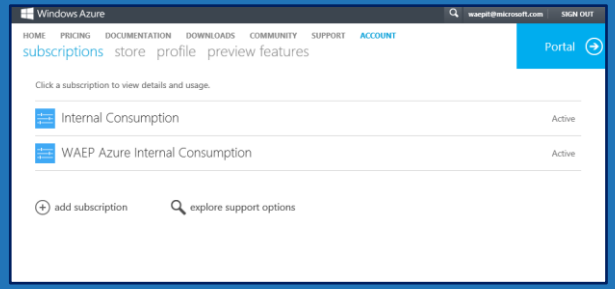


Enterprise subscription & billing management

- Delegation of control (departments)
- Billing information
- Reporting / billing API

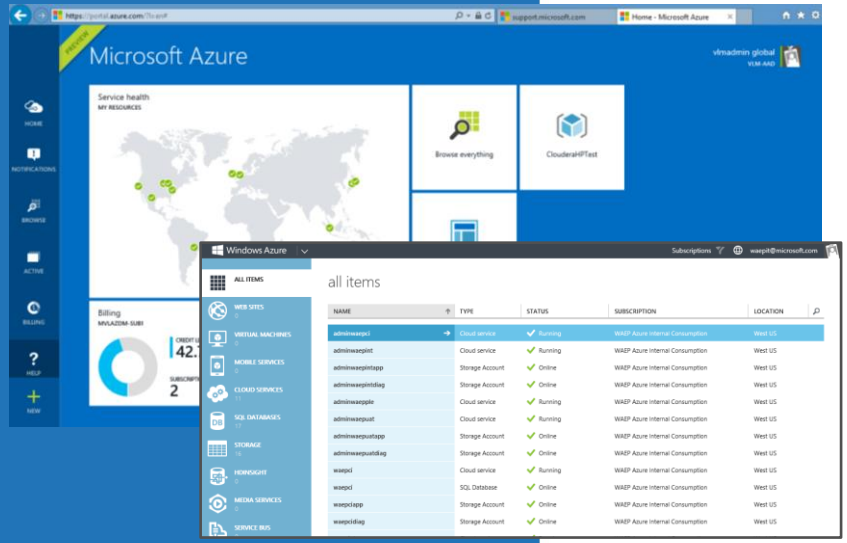
Account portal

- Subscription management
- Preview features

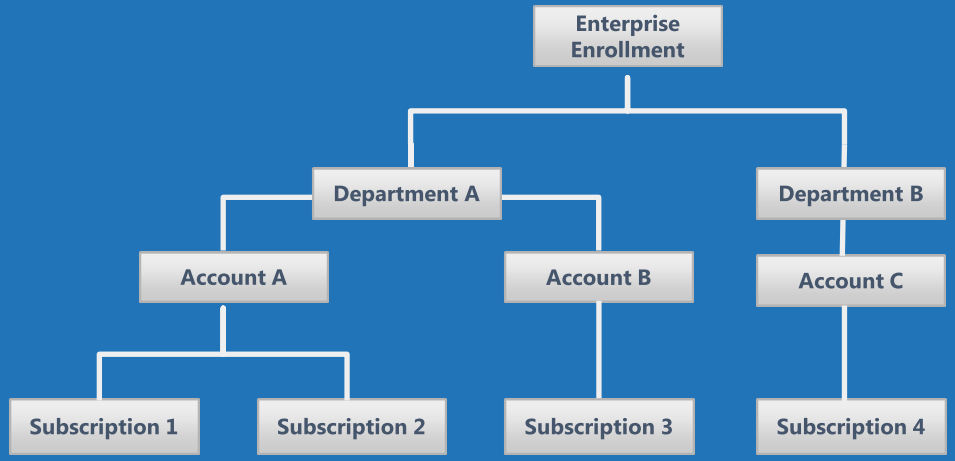


Management portals

- Service catalog
- Deploy
- Delete
- Configure
- Monitor
- Manage
- Operate…



Enterprise Azure Roles



Enterprise Portal	**Enterprise Administrator** -The Enterprise Administrator has the ability to add other Enterprise and Department Administrators, add Departments, add or associate Accounts to the Enrollment, can view usage and charges data across all Accounts and Subscriptions, can view the monetary commitment balance associated to the Enrollment. There is no limit to the number of Enterprise Administrators on an Enrollment. You can also add a Notifications Contact that can receive all email notifications. **Department Administrator** - The Department Administrator has the ability to edit their department name and cost center, manage department admins, add accounts to the enrollment and their departments, remove accounts from their departments and view Department charges if enabled by the Enterprise Admin.
Account Portal	**Account Owner** - The Account Owner can add Subscriptions for their Account, update the Service Administrator and Co-Administrator for an individual Subscription, view usage data for their Account, and view Account charges if enabled by the Enterprise Administrator. The Account Owner will not have visibility of the monetary commitment balance unless they also have Enterprise Administrator rights.
Mgmt Portal	**Service Administrator** - The Service Administrator and up to 199 Co-Administrators per Subscription have the ability to access and manage Subscriptions and development projects within the Azure Management Portal. The Service Administrator does not have access to the Enterprise Portal unless they also have one of the other two roles.

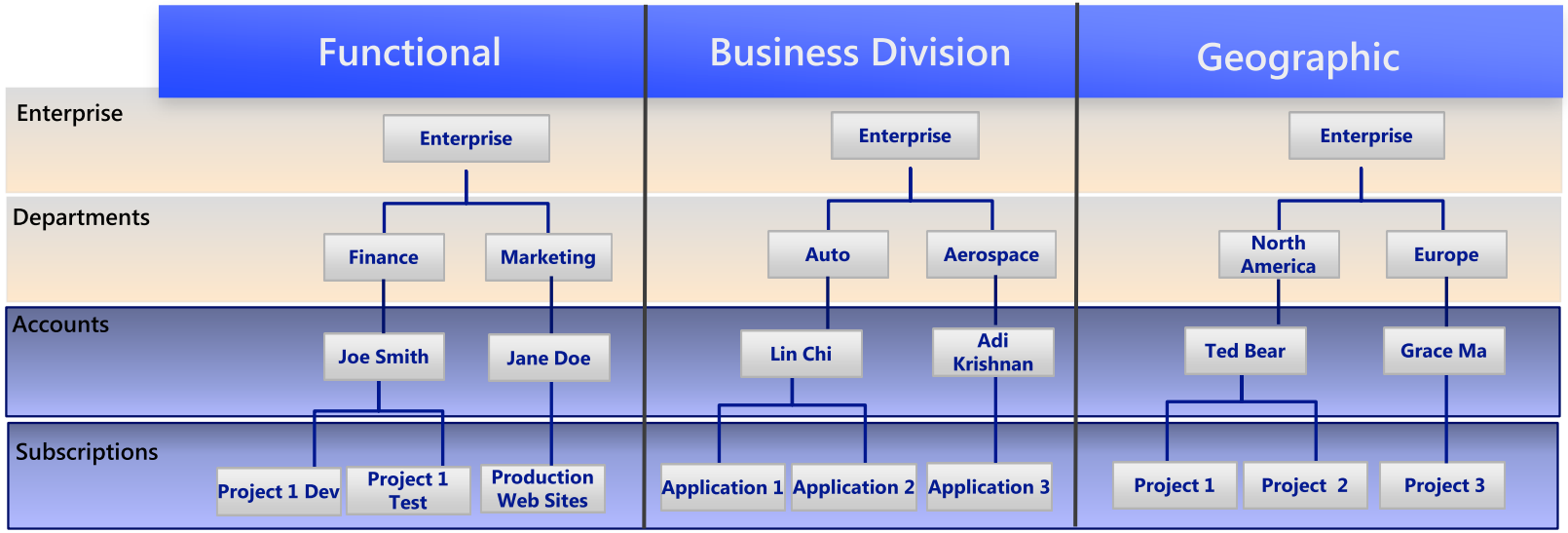
Department/Account/Subscription Setup

Functional Teams
Finance, Marketing, Sales, etc.

Geographic Locations
North America, Europe, Asia, etc.

Business Divisions
Automotive, Aerospace, Medical, etc.

Applications
Application 1, Application 2, etc.



Best practices

- MSFT ID's versus AAD (Work & School accounts)
- Move to one AAD (per organization)
- Organizational models vs. minimizing the number of subscriptions
- Use delegation of control (Access control)
- Prevent subscription sprawl – enable subscription management!

Principles Azure governance & AAD (1/3)

- Each portal is an application in itself, with their own merits
  - AuthN: against AAD or MSFT-ID
  - AuthZ: internal to app
  - Note: subscription administration different than AAD administration
- Subscriptions associated with only one AAD tenant!
- All admin roles member from that AAD tenant!
  - Exception: MSFT service admin, but cannot create co-admin if outside AAD tenant
  - Beware: WSA Account owner can assign a service administrator from his own AAD tenant to a subscription that is associated to a different AAD tenant!
- Co-Admin maybe sourced from different tenant.
  - Not the service admin, must be native in the AAD tenant (or an MSFT ID)
  - Might need to add the tenant to the management portal url "/tenantname.onmicrosoft.com"
- WSA ID's can create WSA or MSFT admin accounts

TECH DAYS 2015 BREAKING NEW GROUND
Microsoft

Principles Azure governance & AAD (2/3)

- MSFT ID's can create only MSFT accounts (privacy reasons)
  - Exception: Co-Admins
  - Exception: EA portal (Account portal and Management portal follow principles)
- WSA can only create accounts from their *own* tenant (or MSFT ID)
  - Exception: EA portal
- When MSFT account has no AAD tenant, a tenant will be created automatically created when logging in to subscription
- Irrespective of the service admin (changed or not), a subscription will be initially connected to one of the existing tenants of the account owner.
  - If WSA account owner moves subscription to MSFT account before logon, what happens? Nothing
- If you want to connect to existing O365 tenant: create/use a WSA service account from that tenant before first logon.

TECH DAYS 2015
BREAKING NEW GROUND
Microsoft

Principles Azure governance & AAD (3/3)

- You can sign up as an organization, if no AAD tenant exists.
- Only MSFT ID's can reassociate subscriptions to a different tenant!
  - Downtime → No, but… Azure automation / REST API access: all changed!
- You can add an existing tenant for management to your subscription
  - Only allowed for MSFT Ids, will sign off, log on to target tenant with WSA and then adds MSFT ID as global admin
  - This allows you to manage that Tenant, and to reassociate the subscription to that tenant (Edit directory)
- EA portal has mixed, single tenant, multi tenant and msft only.
  - What if you need to relocate from MSFT to multiple tenants?
- Move subscriptions:
  - Several ways: data/services migration or subscription account ownership transfer
  - https://msdn.microsoft.com/en-us/library/azure/dn736051.aspx

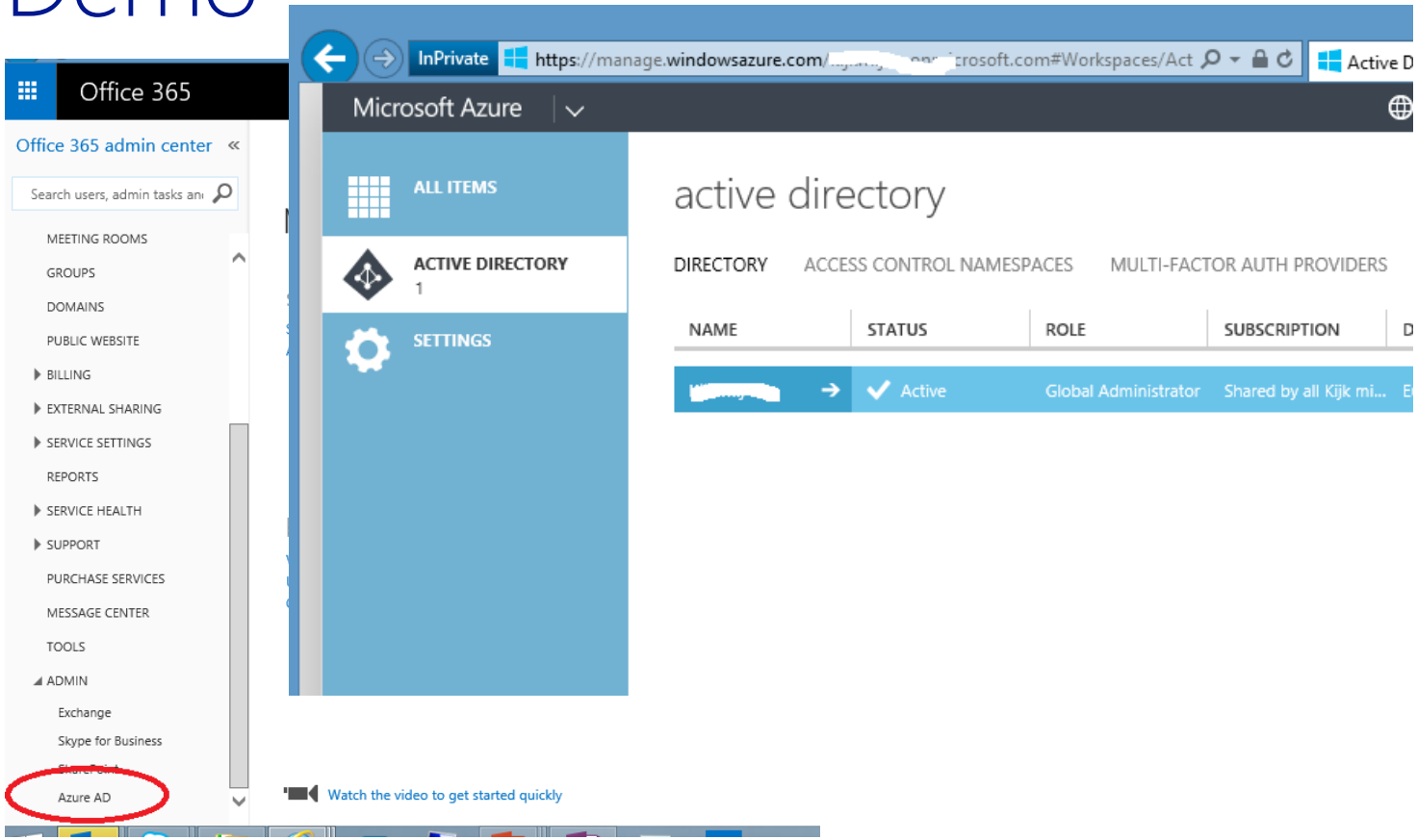
Scenario O365 AAD reuse

Prevent relocation: sign up as an organization

1. Enable view with MSFT in both AAD tenants
   from o365 portal, or add existing directory
2. Change directory
3. Assign co-admins from new directory
4. Ask support to transfer subscription account ownership
5. Change the service-admin to an AAD account in the directory

Microsoft

Demo



TECH DAYS 2015
BREAKING NEW GROUND
Microsoft

Subscription level resource control

Azure resource manager

Tools

Microsoft Azure

+

Command Line

+

Visual Studio

AZURE RESOURCE MANAGER API

RESOURCE MANAGER

Cloud + On-Premises

ADFS

AAD

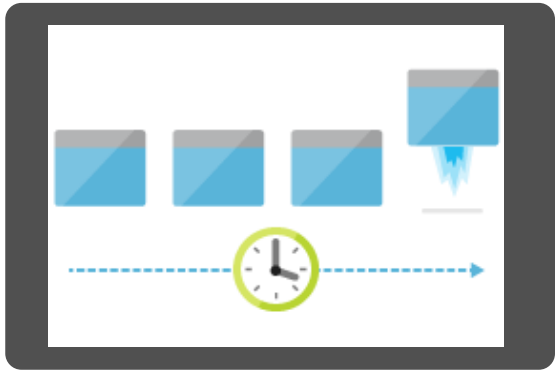
RESOURCE PROVIDER CONTRACT

Provider
Rest Points

Consistent
Management
Layer

Microsoft

Areas of Focus



Deploy

- template-driven
- declarative
- idempotent
- multi-service
- multi-region
- extensible

- resource groups
- linked resources
- tags

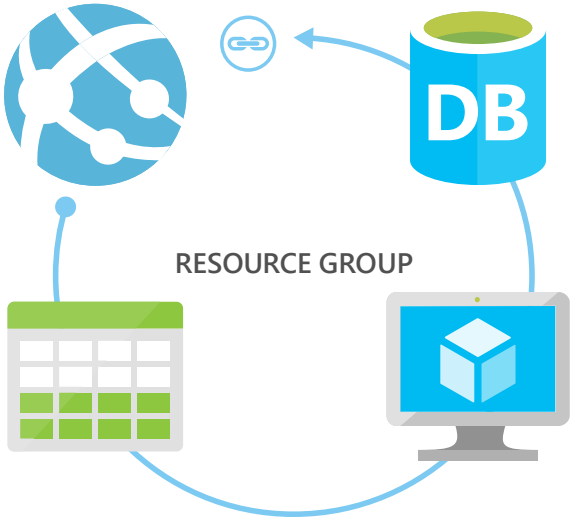
Organize

- role based access control
- audit logs
- resource locks

Control

Microsoft

Resource Group



→ container for multiple resources
→ resources exist in one* resource group
→ resource groups can span regions
→ resource groups can span services

*and only one

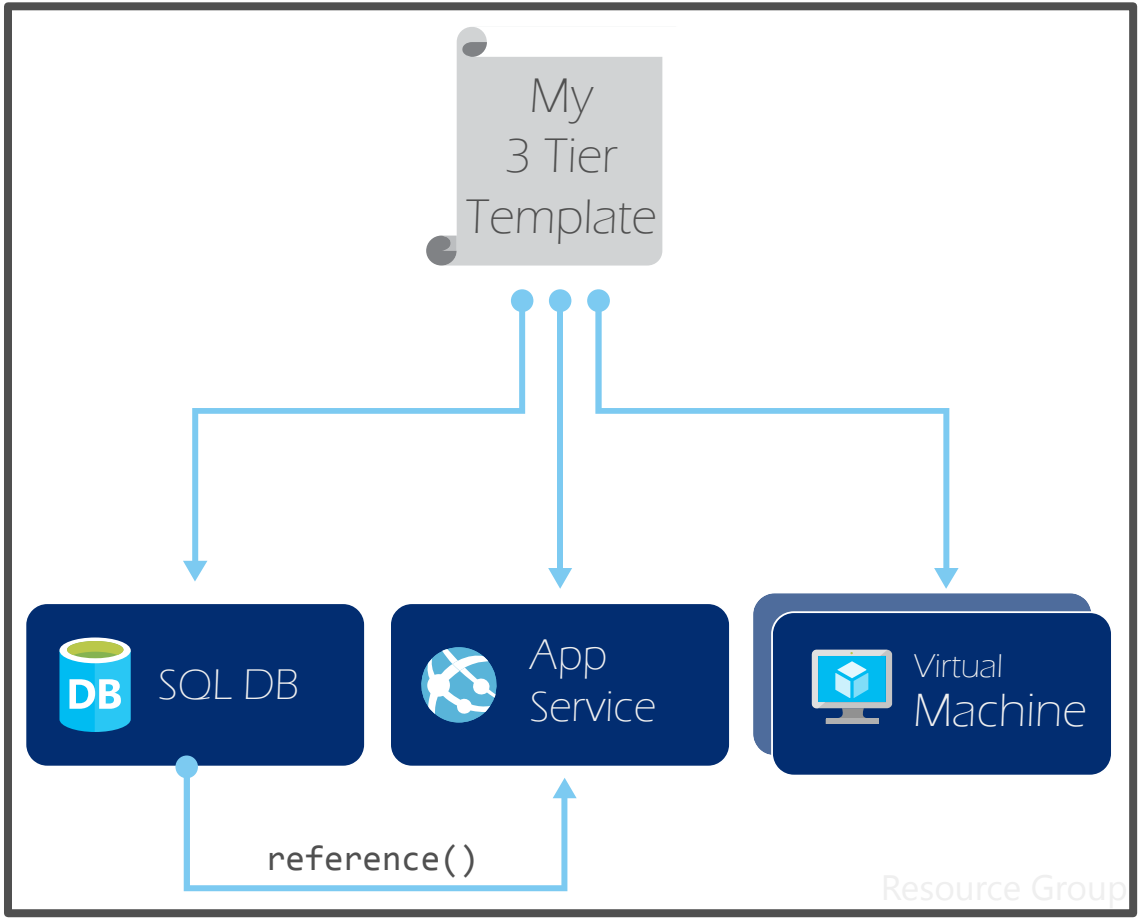
A deployment within a resource group:
→ tracks template execution
→ created within a resource group
→ allows nested deployments

TECH DAYS 2015
BREAKING NEW GROUND
Microsoft

Advanced Template Scenarios

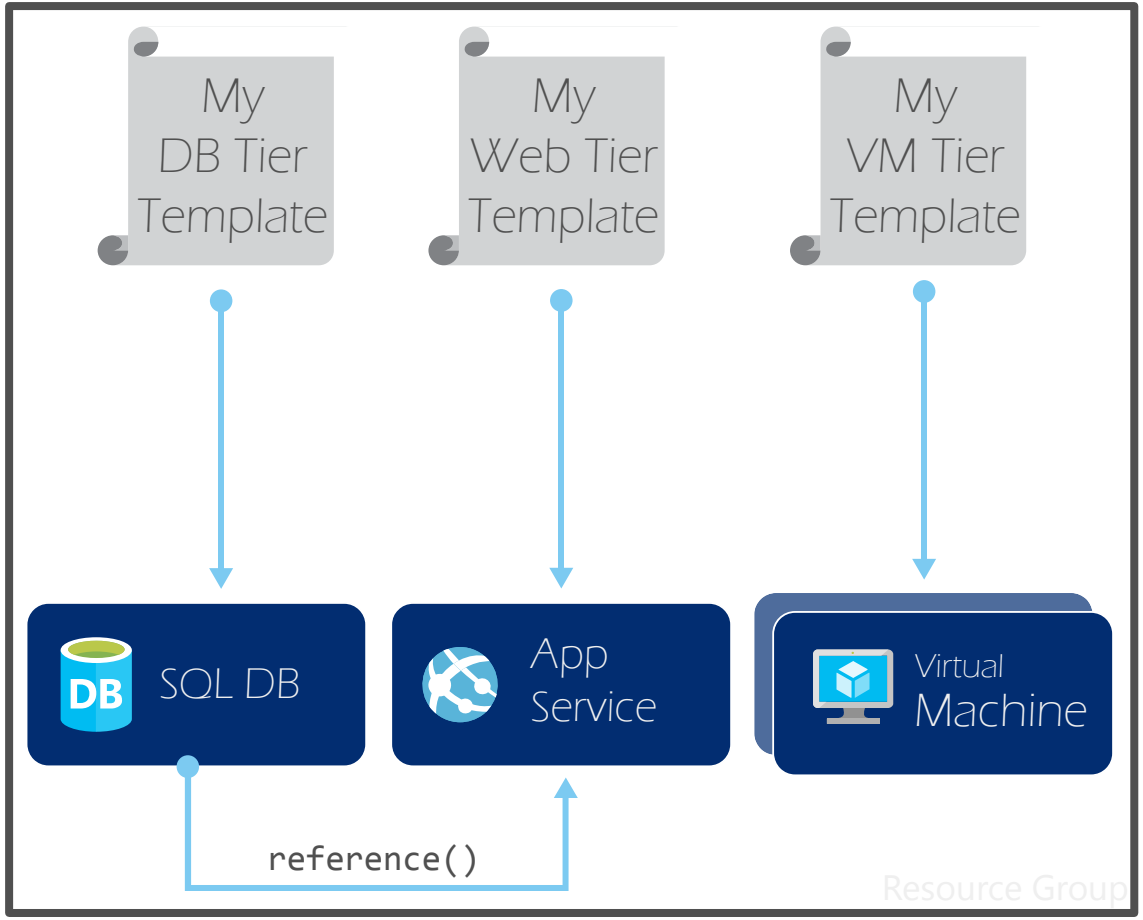
- Resource Extensions
  - VM+DSC/Chef/Puppet/CustomScript/etc.
  - AppService + WebDeploy
  - SQL DB + BACPAC
- Copies
- Nested Templates

Resource group & template design options



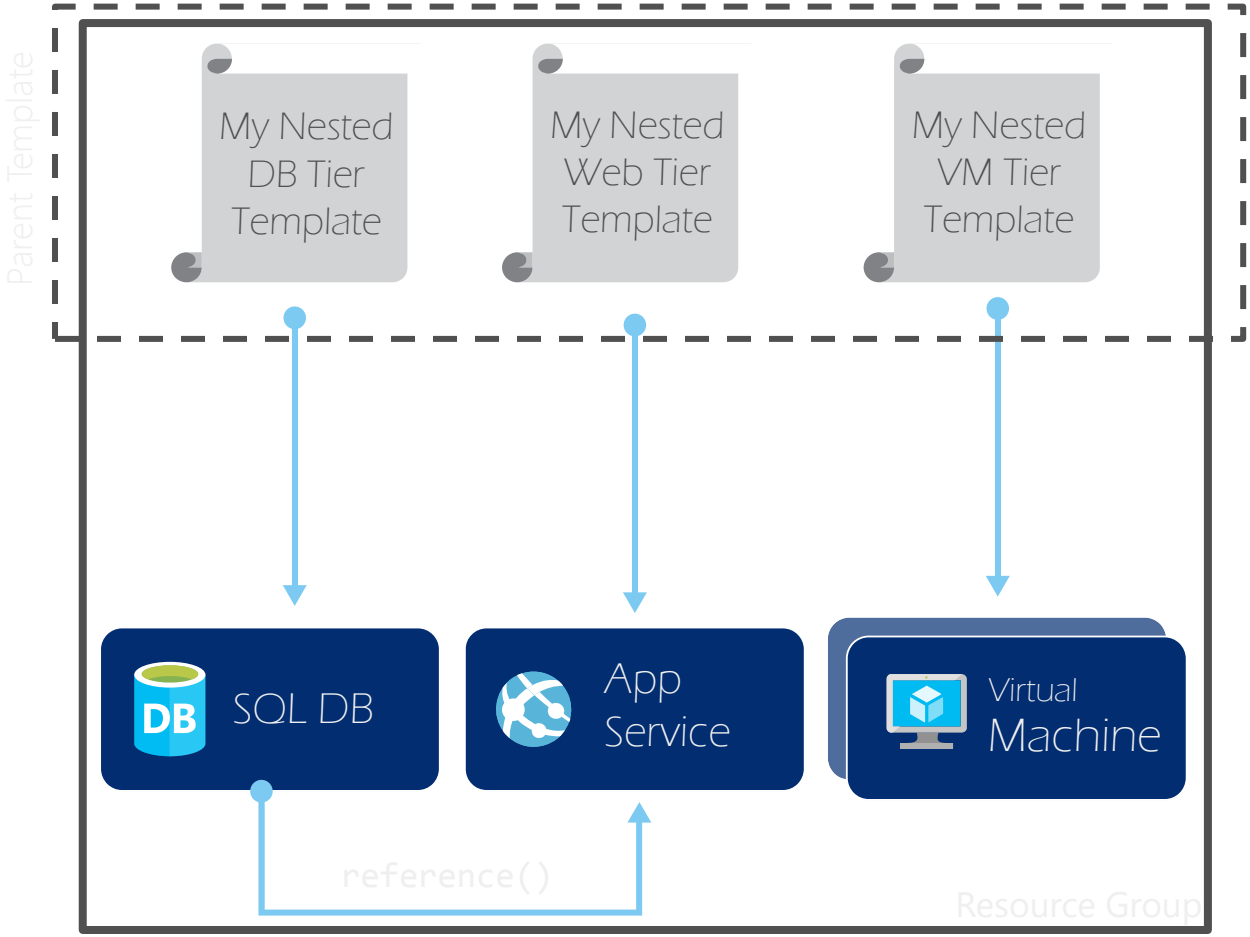
App-centric
Resource Groups
and Templates

Resource group & template design options



App-centric Resource Groups and Tier-centric Templates

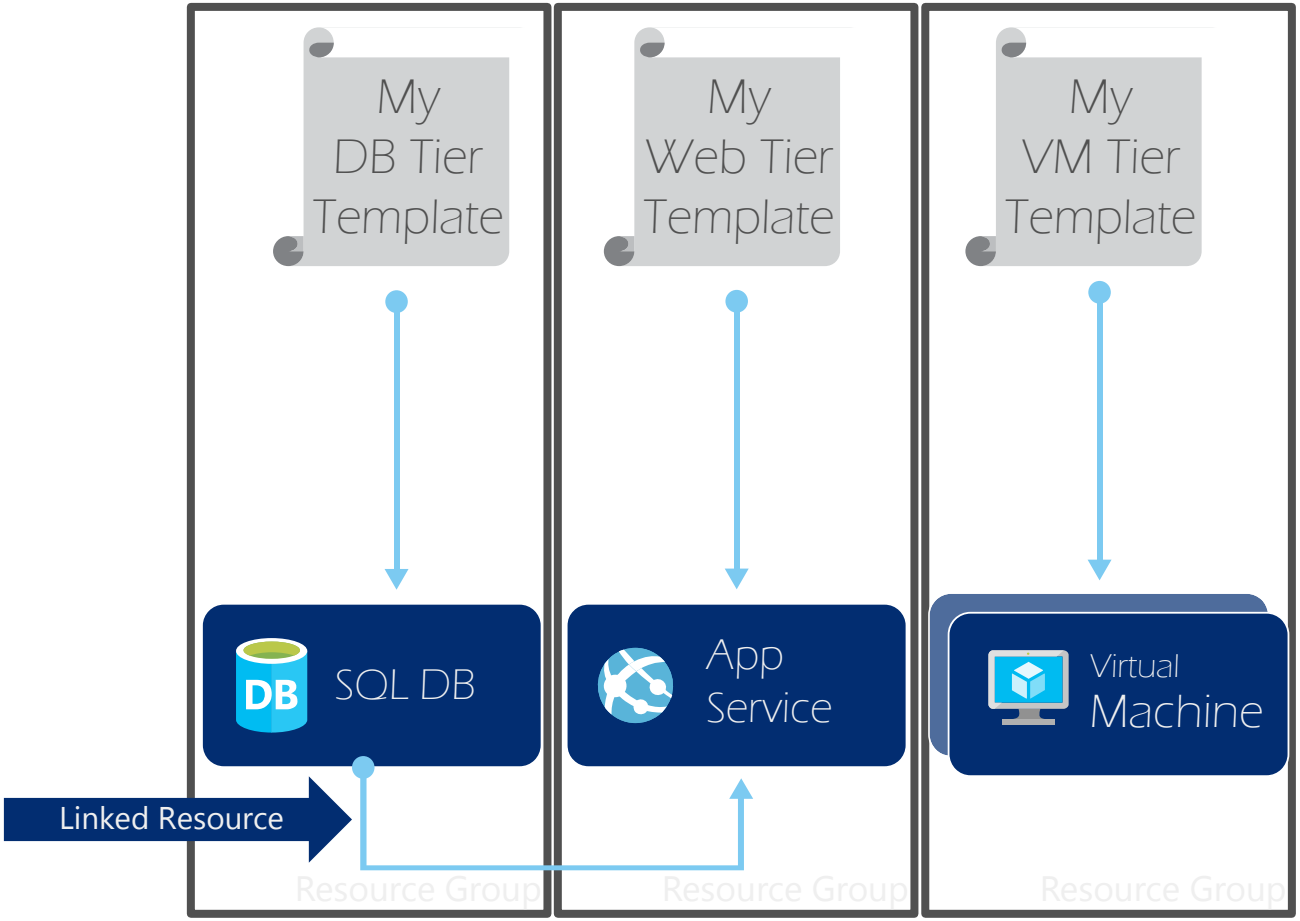
Resource group & template design options



App-centric Resource Groups and Nested Templates

TECH DAYS 2015
BREAKING NEW GROUND
Microsoft

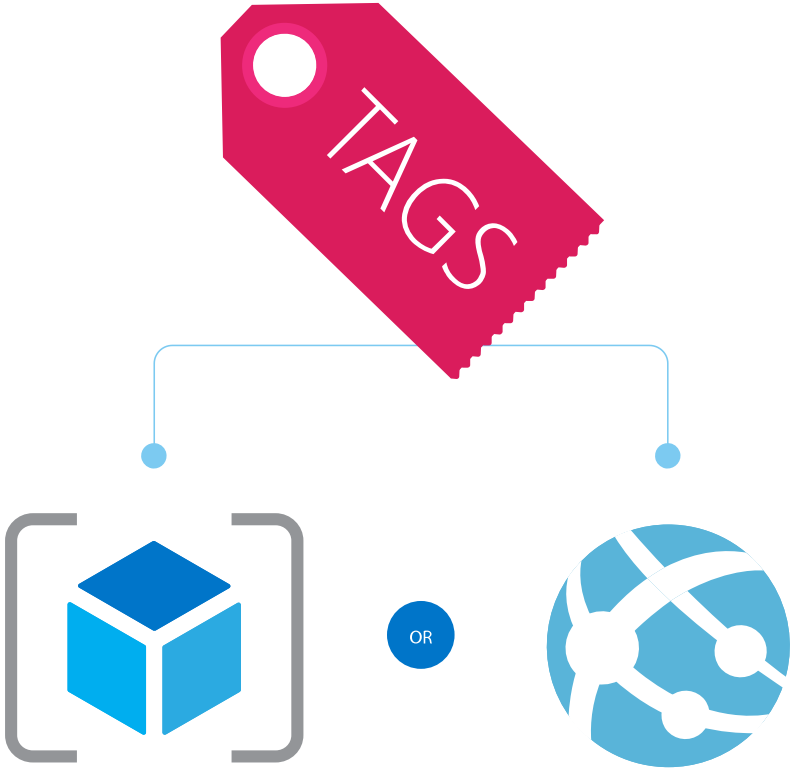
Resource group & template design options



Tier-centric
Resource Groups
and Templates

TECH DAYS 2015
BREAKING NEW GROUND
Microsoft

Resource Tags



Name-value pairs assigned to resources or resource groups

Subscription-wide taxonomy

Each resource can have up to 15 tags

Best practices / uses

- Tag by environment, e.g. dev/test/prod
- Tag by role, e.g. web/cache/db
- Tag by department, e.g. finance/retail/legal
- Tag by responsible party, e.g. Bob

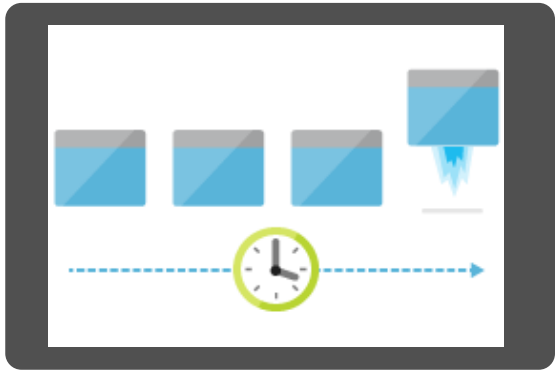
Microsoft

Demo

Microsoft

Access control & monitoring

Areas of Focus



Deploy

- template-driven
- declarative
- idempotent
- multi-service
- multi-region
- extensible

- resource groups
- linked resources
- tags

Organize

- role based access control
- audit logs
- resource locks

Control

TECH DAYS 2015
BREAKING NEW GROUND
Microsoft

Access control in cloud is key!

- Mitigate risk of compromised accounts
  - Multi-Factor Authentication (Azure MFA / Windows Server ADFS)
- Limit excessive permissions – least privilege
  - Azure AD Role Based Access Control (RBAC)
  - Azure AD Privileged Identity Management (temporary/'JIT' access controls)
- Detect insider compromise or abuse of privileges
  - Azure auditing and logging
  - Azure AD anomaly detection and analysis

Compromised accounts

Preventing accounts with weak authentication methods

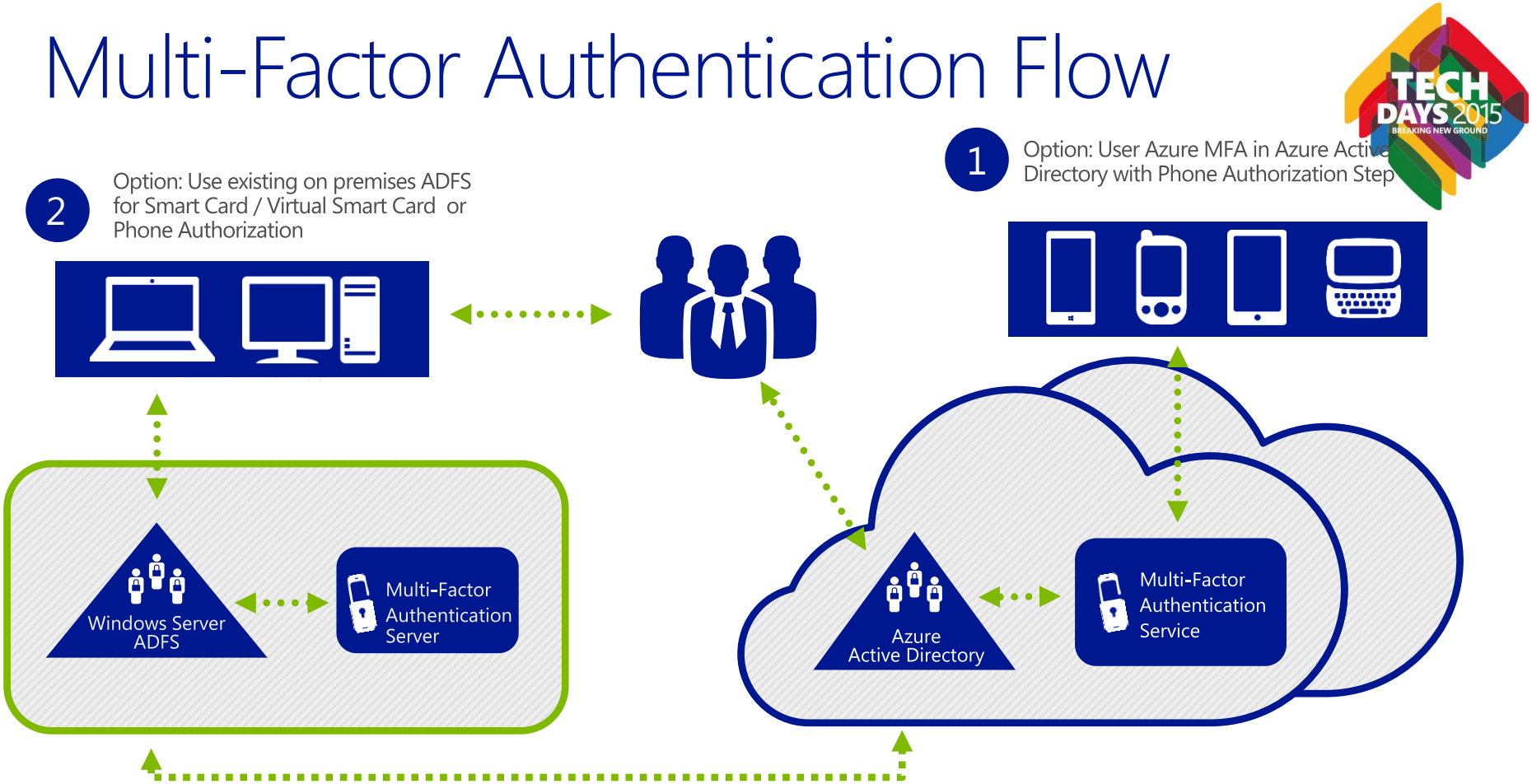
Secure your user accounts with Azure MFA

- Can be used with Azure Active Directory or Windows Server Active Directory Federation Services (ADFS)
- Provides a second factor (e.g. phone or device) as a second factor

Secure your user accounts with Smart Cards with Windows Server ADFS & AAD

- Use your existing PKI (Smart Card, Virtual Smart Card) to secure accounts by using Azure AD accounts federated to your on premises infrastructure

Multi-Factor Authentication Flow



Microsoft

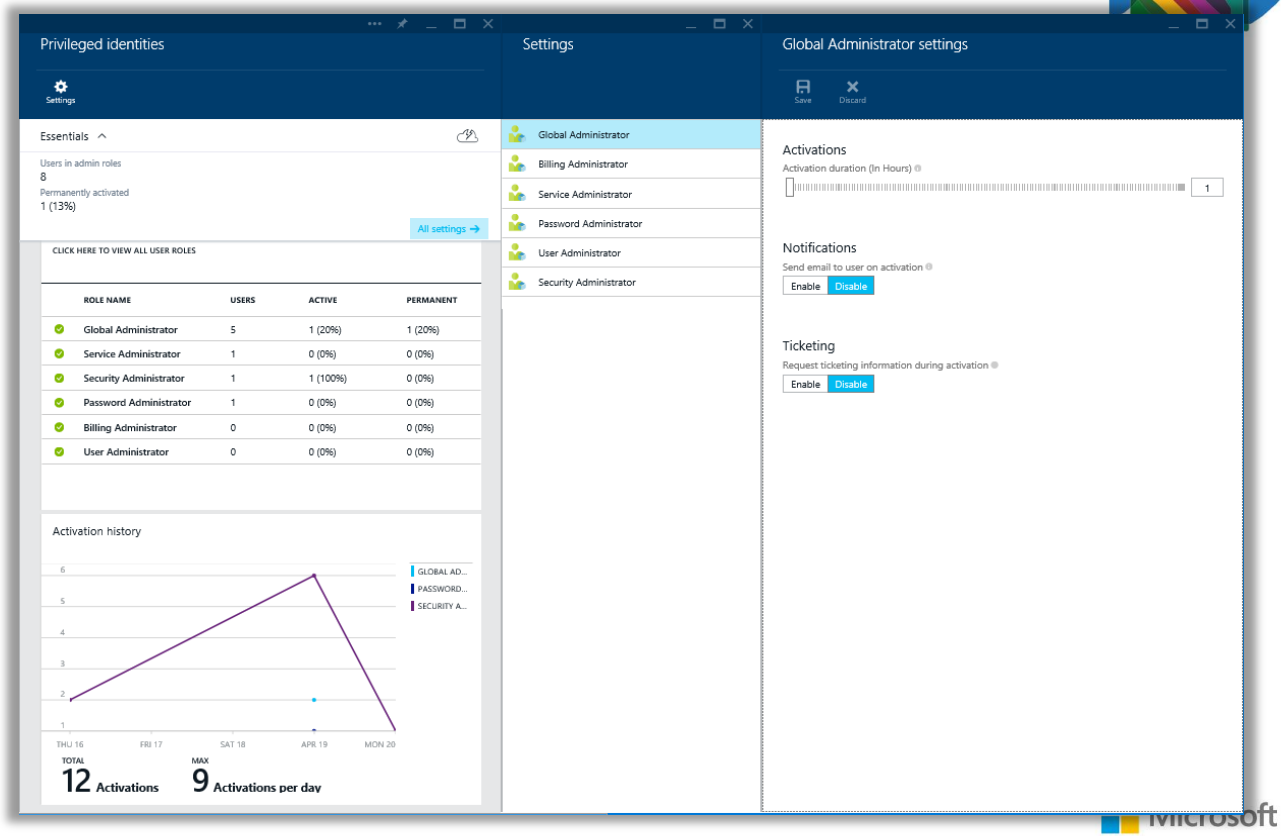
Controlling privileged accounts

- Superuser accounts have special risk and deserve special management.
- Enable "Just In Time" (JIT) privileged access
  - Reduces attack surfaces from multiple different types of attacks (compromised accounts, XSS, etc.)
  - Also prevents common operational mistakes "I thought I was deleting the test tenant"
  - Enhances monitoring of admin activity – and understanding of how often privileged access is used
- Microsoft uses this paradigm to protect Azure
  - No standing access
  - Temporary, specifically scoped elevations to resolve incidents & provide support
- Customers can now benefit from this learning – Azure AD Privileged Identity Management

Microsoft

PIM: View permissions & set policies

- Simple view of all admin role assignments
- Track overall % of permanent vs. temporary authorizations
- Set policies to transition permanent role assignments to temporary assignments



Role Based Access Control

Allows secure access with granular permissions
Assignable to users, groups, or service principals
Built-in roles make it easy to get started

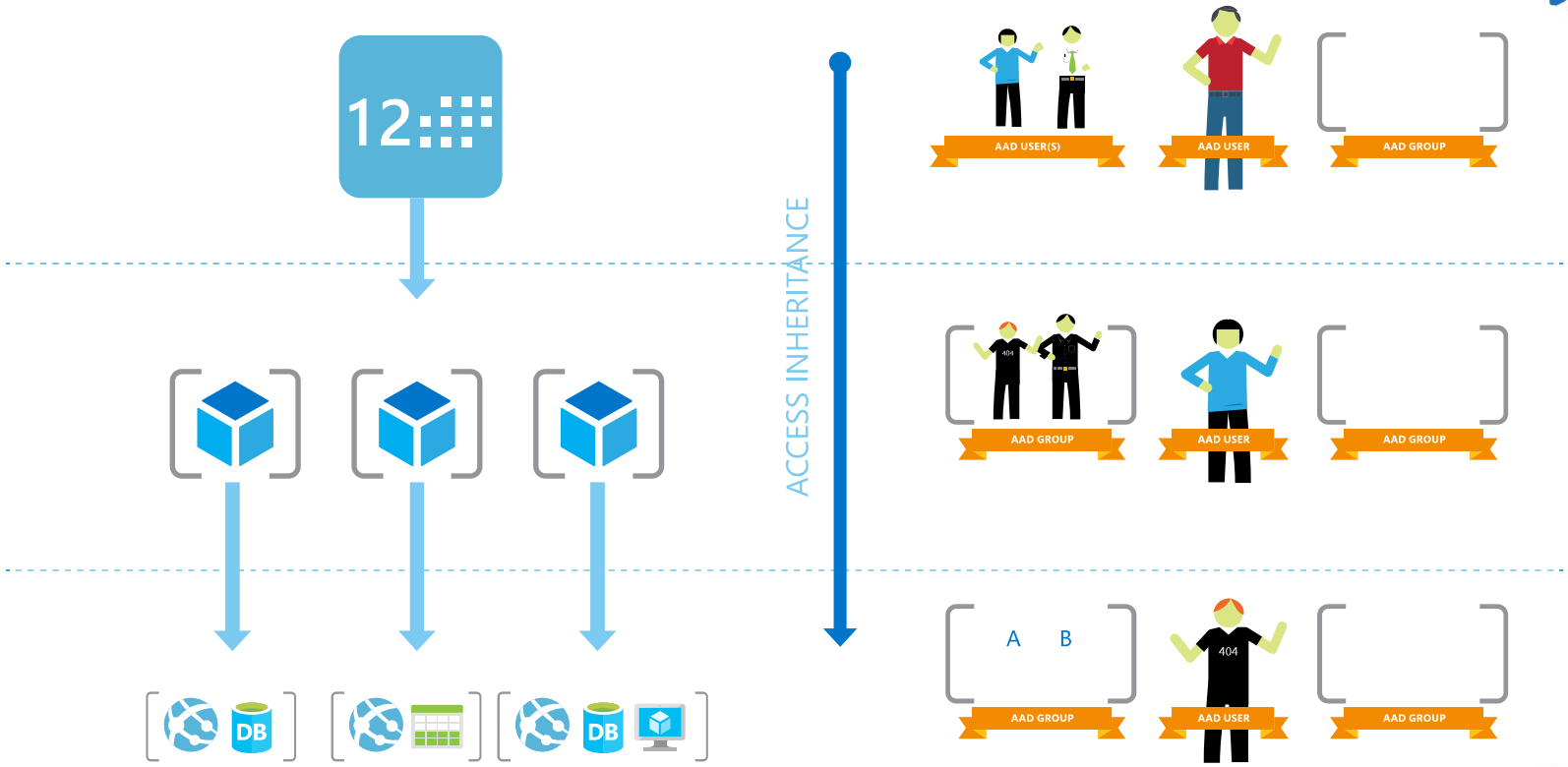
Role Definitions

- describes the set of permissions (e.g. read actions)
- can be used in multiple assignments

Role Assignments

- associate role definitions with an identity (e.g. user/group) at a scope (e.g. resource group)
- always inherited – subscription assignments apply to all resources

Role Based Access Control scope/inheritance



Microsoft

Granular Scopes

/subscriptions/{id}/resourceGroups/{name}/providers/.../sites/{site}

subscription level – grants permissions to all resources in the sub

resource group level – grants permissions to all resources in the group

resource level – grants permissions to the specific resource

Microsoft

Resource Locks

Accidents happen, resource locks help prevent them

Resource locks allow administrators to create policies which prevent accidental deletion.

- Resource lock
  - Policy which enforces a "lock level" at a particular scope
- Lock level
  - Type of enforcement; currently supports CanNotDelete
- Scope:
  - The realm to which the lock level is applied. Expressed as a URI; can be set at the resource group, or resource scope.

Microsoft

Auditing & logging

Effective auditing is foundational for monitoring user activity (and thus detecting attacks)

- Azure management operations are audited
  - journals all write/delete/actions
  - Access management actions
  - central location & common format
  - User / client / source IP address
  - Available in UI or query service management API / RM API
- Azure Active Directory management audit
  - All tenant admin activity logged – these are the 'global' admins, largest impact if compromised
- Azure AD PIM admin activations audit

Microsoft

Key Access Learnings Enterprise Customers

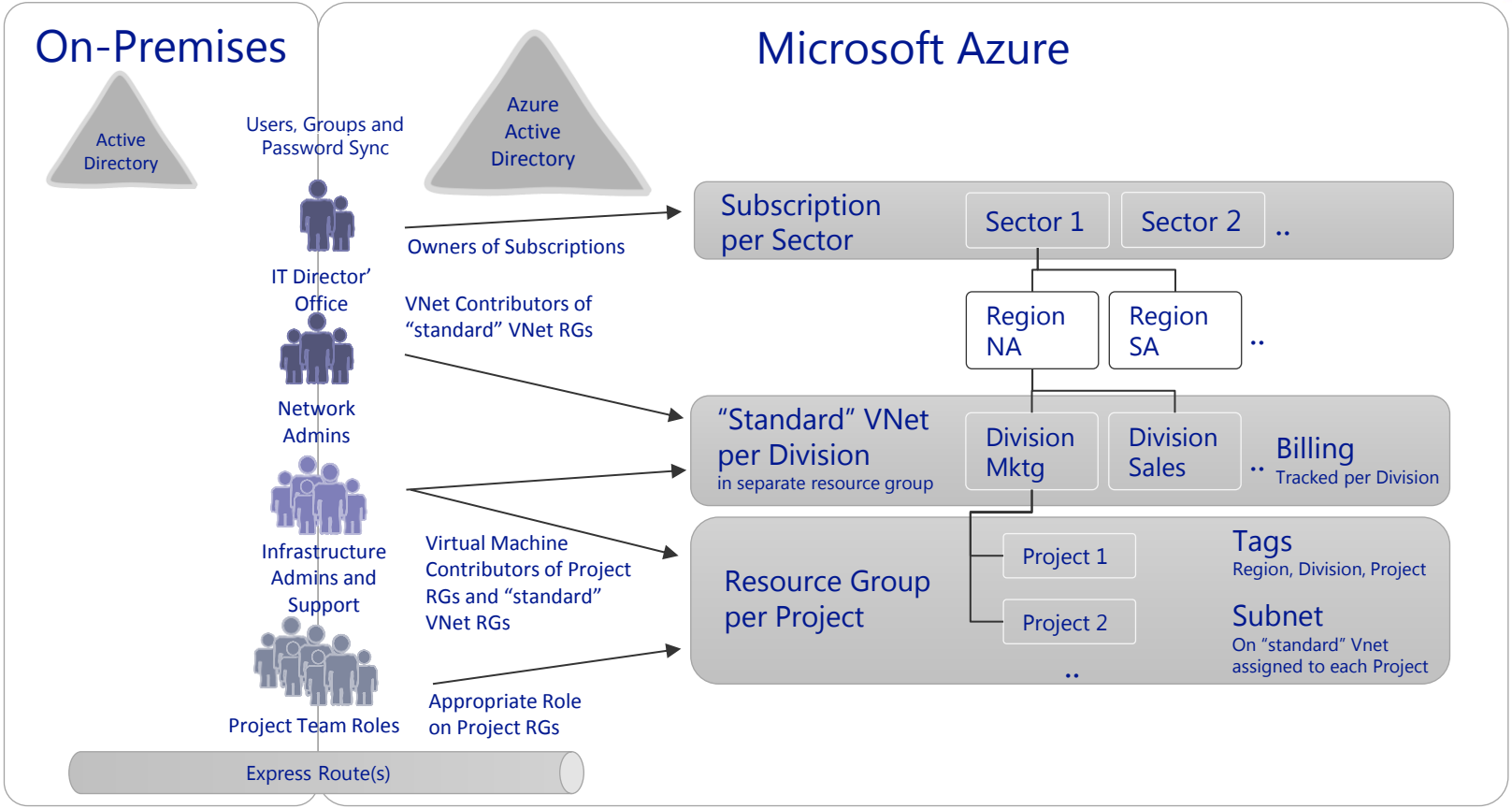
- Transition to using Azure RBAC
- Manage Access using group assignments (dynamic groups/ABAC)
  - Assign access to AD groups, manage membership of groups for on-going access management.
- Enable Multi-Factor Auth
  - Use Azure AD conditional access policies to enable MFA for Azure management.
- Least Privilege
  - Pick the right role for the job. Contributor not Owner. Model on-premises roles using resource-type specific Azure roles.
- Keep a tab on Access Changes
  - Monitor changes to access settings. Regularly dump and review entire access policy.

Demo

Microsoft

Scenario sample

Sample enterprise implementation



Your feedback is important!
Scan the QR Code and let us know via the TechDays App.

Thank you!

Laat ons weten wat u van de sessie vindt via de TechDays App!
Scan de QR Code.

MVA

Microsoft Virtual Academy

Bent u al lid van de Microsoft Virtual Academy?! Op MVA kunt u altijd iets nieuws leren over de laatste technologie van Microsoft. Meld u vandaag aan op de MVA Stand. MVA biedt 7/24 gratis online training on-demand voor IT-Professionals en Ontwikkelaars.

Microsoft

TECH DAYS 2015

BREAKING NEW GROUND

Microsoft